

事件驱动智能体操作系统跨层能力治理方法

(人工智能操作系统及其安全专刊)

徐刚^{1,3}, 冯骐^{2,*}, 姚俊杰³, 肖宇³, 陈铭松³, 王江涛^{1,3}, 杨世光³, 饶振宇³, 王语欣³

¹ (华东师范大学国家可信嵌入式软件工程技术研究中心, 上海)

² (华东师范大学信息化治理办公室, 上海)

³ (华东师范大学软件工程学院, 上海)

通讯作者: 冯骐, E-mail: qfeng@admin.ecnu.edu.cn

摘要: 事件驱动智能体操作系统将外部事件转化为自主任务并发起工具调用, 但事件来源、任务创建与工具执行分属不同信任域, 协议格式校验或单点动作过滤无法证明一次工具调用获得了完整链路授权。本文提出事件到智能体治理 (Event-to-Agent Governance, E2AG) 方法, 将事件接入、任务创建和工具调用三个阶段的授权约束统一纳入任务作用域的能力生命周期。E2AG 通过来源-类型契约和目标策略完成任务准入, 为获准任务签发对象绑定的短期能力, 并在实际模型上下文协议 (Model Context Protocol, MCP) 调用抵达上游前实施第二次强制验证; 统一执行证据用于检查授权依赖和定位治理失败。本文给出跨层授权状态模型、完整中介安全性质及其证明概要, 并在事件驱动智能体操作系统原型上实现该方法。基于经盲表复核的冻结治理矩阵、合成压力集、持久化端到端执行、既有模型工具决策回放、自有设施治理一致性回归和并发故障注入进行评估。评估结果表明, 在所测试场景中, 完整方法保持了全部直接准入事件的可用性, 并对冻结治理矩阵中全部非直接准入事件作出预期的拒绝或审批判定。消融实验显示, 移除任一执行点都会使依赖该执行点上下文的未授权工具调用到达上游。

关键词: 人工智能操作系统; 智能体操作系统; 能力治理; 完整中介; 执行溯源

中图法分类号: TP311

A Cross-Layer Capability Governance Method for Event-Driven Agent Operating Systems

XU Gang^{1,3}, FENG Qi^{2,*}, YAO Junjie³, XIAO Yu³, CHEN Mingsong³, WANG Jiangtao^{1,3}, YANG Shiguang³, RAO Zhenyu³, WANG Yuxin³

¹ (National Trusted Embedded Software Engineering Technology Research Center, East China Normal University, Shanghai, China)

² (Information Governance Office, East China Normal University, Shanghai, China)

³ (School of Software Engineering, East China Normal University, Shanghai, China)

Abstract: Event-driven agent operating systems transform external events into autonomous tasks and tool invocations. Event provenance, task creation, and tool execution nevertheless belong to distinct trust domains, so protocol validation or a single action filter cannot establish that a tool invocation is authorized by the complete execution chain. This paper presents Event-to-Agent Governance (E2AG), a cross-layer capability-governance method that organizes event-admission, task-creation, and tool-invocation authorization constraints into a task-scoped capability lifecycle. E2AG admits tasks through source-type contracts and target policies, issues an object-bound short-lived capability for each admitted task, and enforces the capability again before an actual Model Context Protocol (MCP) call reaches its upstream tool. Unified execution evidence checks authorization dependencies and localizes governance failures. We define a cross-layer authorization transition model and a complete-mediation safety property with a proof sketch, and implement E2AG in an event-driven agent operating system prototype. Evaluation uses a blindly reviewed frozen governance matrix, a synthetic stress suite, persistent end-to-end executions, replay of previously frozen model tool decisions, a governance-consistency regression on self-operated facilities, and concurrent fault injection. The results show that, in the tested scenarios, the complete method preserves the availability of all directly admissible events and produces the expected denial or approval decision for every non-directly admissible event in the frozen governance matrix. The ablation study shows that removing either enforcement point allows unauthorized tool invocations that depend on context available only at that point to reach the upstream tool.

Key words: artificial intelligence operating system; agent operating system; capability governance; complete mediation; execution provenance

引言

本文将人工智能操作系统（Artificial Intelligence Operating System, AIOS）作为上位概念，指以人工智能（Artificial Intelligence, AI）为原生能力、为模型、智能体与系统资源提供统一运行支撑的系统软件范式；将其中面向智能体工作负载，统一管理模型、记忆、工具、生命周期、任务调度和访问控制的具体形态称为智能体操作系统（Agent Operating System, Agent OS）。AIOS 工作以代理应用与内核资源隔离为出发点，在内核中提供调度、上下文、记忆、存储和访问控制等服务 [1]；自主智能体综述则将画像、记忆、规划和行动概括为统一框架的主要模块，其中行动模块包括工具使用与环境交互 [2]。本文聚焦事件驱动 Agent OS：Git 推送、邮件、监控告警和业务回调不再只是被动输入，而可以直接创建智能体任务。任务运行时读取事件载荷，调用模型选择工具，再由 MCP 或其他连接器访问代码仓库、数据库、消息系统和设备。与传统请求-响应应用相比，这条链同时包含不可信事件输入、非确定性模型决策和可能改变外部状态的工具调用；治理问题因而不只是“模型选择了什么动作”，而是“该动作能否沿系统路径获得执行权”。

考虑如下贯穿全文的例子。一个多智能体博弈平台在参与者向公开测试代码库推送提交后，向本文 Agent OS 原型的隔离测试服务器发送标准化的 `git.push` 事件 e 。服务器选择变更分析智能体 a 并创建任务 t ；目标策略只允许该任务使用记录推送、记录评审和查询记录等工具，因此系统签发绑定 e, t, a 与允许集合 $U(g)$ 的短期能力 g 。运行时产生的工具调用 c 若属于 $U(g)$ ，调用时策略执行点（policy enforcement point, PEP）才将其转发到上游；若模型选择固定的集合外状态修改工具，PEP 在接触上游前返回拒绝。该允许-拒绝配对对应本文自有设施上的治理一致性回归，但不用于估计自然流量中的模型违规概率。

同一例子给出两个单点机制无法覆盖的反事实分支。若事件伪造来源字段但最终选择集合内工具，仅位于调用时的 PEP 看不到来源声明权，必须由任务创建前的 PEP 阻断；若来源与任务均已获准，但运行时选择集合外工具，调度前 PEP 尚未观察到实际调用 c ，必须由调用时 PEP 再次验证。两条分支分别对应第 6 节的任务准入消融和上游调用可达性实验，说明问题不是重复增加规则，而是让授权依据随事件、任务和工具对象跨层传播。

CloudEvents、智能体间协议（Agent2Agent, A2A）和 MCP 分别规定事件、任务和工具调用对象 [16, 17, 18]，但协议互操作不自动产生跨对象授权。间接提示词注入评测揭示了不可信内容改变工具决策的风险 [6, 7, 8, 9]；AgentSpec 和 CaMeL 等工作把确定性约束置于模型之外 [10, 11]。这些机制分别保护事件格式、运行时动作或数据流，却没有共同回答三个问题：谁有权声明某类事件，该事件能否创建指定智能体任务，以及任务发起的工具调用能否到达上游并改变外部状态。经典参考监控器要求安全相关访问受到不可绕过的完整中介 [20, 21]；在事件驱动 Agent OS 中，单个执行点无法同时观察三个对象，完整中介必须跨层组织。

本文把上述问题抽象为跨层授权传播：系统接收不可信事件后，应当逐步收缩而不是隐式扩大权限。事件来源只能声明契约允许的类型；获准事件只能创建目标策略允许的任务；任务只能使用绑定到其事件、智能体、MCP 服务和工具集合的短期能力。任何到达上游的工具调用，都应存在可验证的事件-任务-能力-调用依赖。该目标还要求审批、能力过期和事件重放采用单调、原子的状态转移，否则正确的策略判定仍可能被并发态破坏。

基于这一抽象，本文提出 E2AG 方法。E2AG 由治理平面、执行平面和证据平面组成：治理平面拥有来源-类型契约、目标策略、审批和任务能力状态；执行平面在任务创建前与工具调用前设置两个不可绕过的 PEP；证据平面把两个执行点及其对象依赖写入同一 `trace`。E2AG 不检测自然语言是否恶意，而是在模型之外决定一次任务和一次工具调用是否具有完整的系统授权。

本文采用状态迁移系统描述事件接入、任务创建、能力签发与工具调用，给出端到端工具调用授权安全性质和双执行点完整中介命题。该形式化不是装饰性符号：任务接入性质由 $\text{Contract} \times \text{Policy}$ 消融检验，调用授权安全性质由固定模型决策的配对执行检验，证据连续性和状态单调性分别由故障注入与并发态检验。

本文的主要贡献如下：

1. 提出事件驱动 Agent OS 的跨层授权问题，统一刻画事件声明权限、任务创建权限与工具调用权限，给出可由算法和实验共同检查的安全性质；
2. 设计 E2AG 三平面架构、任务作用域能力和双执行点完整中介算法，使工具调用不能脱离触发它的事件与任务单独获得权限；
3. 在真实事件驱动智能体操作系统原型中实现 E2AG，并通过完整消融、独立策略引擎基线、持久化端到端执行、既有模型决策配对回放、故障注入和并发状态实验验证各机制的独立作用与组合效果；
4. 公开区分已验证范围与外部有效性边界：当前证据支持单一 Agent OS 原型上的上游调用可达性与治理状态性质，不外推为任意提示词注入检测、所有工具传输覆盖或跨 Agent OS 通用性。

本文其余部分组织如下：第 1 节介绍相关协议、智能体运行时防护与访问控制基础；第 2 节给出系统模型、不可信输入能力和安全目标；第 3 节介绍 E2AG 总体架构；第 4 节给出跨层治理机制、算法与性质分析；第 5 节说明原型实现；第 6 节报告实验；第 7 节讨论适用边界与有效性威胁；第 8 节总结全文。

1 背景与相关工作

1.1 智能体风险与评测

间接提示词注入源于智能体把不可信数据同时解释为内容和指令，因而可能改变模型行为。InjecAgent 以工具集成任务评估间接注入，AgentDojo 提供包含任务、工具和注入情形的动态环境，ToolEmu 则以模型模拟工具执行结果以扩大长尾风险测试范围 [7, 8, 9]。现有中文综述分别从不同对象梳理相关风险与防护方法：黄河燕等将大语言模型风险归为模型自身安全与生成内容安全，并综述风险评估、归因和缓解方法 [3]；牟奕洋等从敌手目标、知识和能力出发，总结安全威胁与防御技术以及隐私威胁与保护技术 [4]；张熙等归纳大模型智能体的信息泄露、模型攻击、幻觉、伦理和法律合规风险及其防护建议 [5]。上述工作提供风险分类或模型行为评测，E2AG 则不判定自然语言意图类别，而是约束模型决策在真实系统执行链中的可达性。

1.2 智能体运行时防护

AgentSpec 通过领域专用规则描述触发条件、谓词和动作，在智能体运行时强制执行动作规则 [10]。CaMeL 从可信查询提取控制流和数据流，并用能力约束不可信数据对程序流与敏感数据外泄的影响 [11]。二者说明安全决策需要位于模型之外的确定性系统层。新近工作进一步把授权置于工具调用或智能体运行时：开放智能体通行证（Open Agent Passport, OAP）在调用前执行声明式策略并生成签名审计记录 [12]；ToolGuardian 结合工具准入表征与任务感知的声明式授权 [13]；持续智能体语义授权（Continuous Agent Semantic Authorization, CASA）将确定性消息约束与任务-工具语义匹配结合 [14]；Agent libOS 中的 libOS 指库操作系统（library operating system），该方法以显式能力中介进程、工具、资源和审批原语 [15]。这些方法共同证明了调用前授权的重要性，但其授权起点主要是用户任务、运行时进程或待调用工具。E2AG 进一步处理 Connector 外部事件的声明权，并把事件、系统任务和调用能力绑定为同一生命周期。对已授权工具的参数级数据流约束仍应由 CaMeL 类机制或参数谓词补充。

1.3 协议、参考监控器与能力系统

CloudEvents 规定事件格式及上下文属性，A2A 规定智能体发现、消息交互和任务生命周期，MCP 规定主机、客户端与服务器之间的工具发现和调用对象 [16, 17, 18]。这些规范各自包含安全要求，但其标准对象不会自动把一次事件的声明权转换为后续任务创建权和工具调用权限；这是本文基于三类规范边界作出的比较，而非规范自身的结论。仅有对象定义也不足以执行授权。OPA 将策略判定与策略实施解耦，使软件能够向外部策略引擎提交结构化输入并实施其判定 [19]；参考监控器和完整中介原则进一步要求安全相关访问始终经过不可绕过且可充分分析的检查机制 [20, 21]。早期能力系统以能力表表达主体对对象的访问权，Macaroons 则允许持有者通过增加 caveat 对派生凭据进行授权衰减和上下文约束，能力访问控制也可在操作系统内核中进行形式化验证 [22, 23, 24]。在决策能够执行之后，跨层复核还需要关联其对象依赖：万维网联盟（World Wide Web Consortium, W3C）的 Trace Context 支持跨服务传播跟踪标识和供应商状态；数字时间戳中的哈希链接使前后证书相互约束；in-toto 的布局和链接元数据则表达供应链步骤及产物依赖 [25, 26, 27]。E2AG 不把这些机制解释为执行授权证明，而是按“对象定义-授权执行-证据关联”的关系将其组织为事件-任务-工具三层的授权传播和完整中介。

1.4 比较维度与研究定位

表 1 按保护对象、执行点和证据类型比较代表性方法。协议标准不承担治理，现有运行时方法集中于动作、任务意图或数据流；E2AG 同时约束事件声明、系统任务创建和工具调用，并把三个判定关联到同一执行证据。由于这些方法的输入主体和保护对象不同，本文不直接排序其公开结果；数值实验以共享代码路径隔离治理位置，并增加开放策略代理（Open Policy Agent, OPA）独立引擎的工具边界基线，用于区分策略执行器与跨层上下文覆盖。

2 系统模型与问题定义

2.1 问题胶囊与信任边界

本文研究如下系统：多个外部事件源经 Connector 接入 Agent OS，Agent OS 创建智能体任务，模型在任务中选择工具，工具调用可能改变外部资源状态。外部事件源及其载荷不可信；Agent OS 治理代码、策略库和持久化状态属于可信计算基；模型输出不作为授权依据；外部工具只信任经过调用 PEP 的请求。被保护资产是任务创建权限、工具凭据以及外部资源的完整性与可用性。不可信来源可能提交不一致事件字段、重复事件，或通过载荷改变模型工具选择；本文假设其不能直接修改治理代码、策略和数据库。目标是在不分析自然语言意图类别的前提下，使每个到达上游的工具调用都可追溯到合法事件、获准任务和有效任务能力。参数级数据流、治理主机失陷和外部存储整体回滚不在本文范围内。

表 1 代表性方法的治理范围比较

方法	事件来源绑定	任务创建门控	工具调用强制	跨层执行证据
CloudEvents	—	—	—	—
AgentSpec	—	—	✓	局部规则
CaMeL	—	—	✓	控制/数据流
OAP	—	—	✓	签名调用记录
ToolGuardian	—	—	✓	策略判定
CASA	—	—	✓	任务-工具匹配
Agent libOS	—	—	✓	进程/能力记录
E2AG	✓	✓	✓	✓

设来源主体集合、智能体集合和工具服务集合分别为 $\mathcal{S}$ 、 $\mathcal{A}$ 和 $\mathcal{M}$ 。一次执行涉及事件 e 、任务 t 、任务能力 g 和工具调用 c 。本文所称“层次”是授权对象在执行链中的语义层，而不是图 1 中组件职责的架构平面。定义授权层集合

$$\mathcal{H} = \{H_E, H_T, H_C\}, \quad \lambda(e) = H_E, \quad \lambda(t) = H_T, \quad \lambda(c) = H_C, \quad (1)$$

其中 H_E 、 H_T 和 H_C 分别表示事件接入、任务创建和工具调用层； λ 给出对象所属层。“跨层治理”是前一层的授权结论成为后一层对象创建或使用的必要前提，而非三个平面之间的数据流。为刻画这些授权层之间的状态依赖，系统状态写为

$$\Sigma = \langle E, T, G, Q, L \rangle, \quad (2)$$

其中 E, T, G, Q, L 分别保存事件、任务、能力、审批状态和执行证据。该状态直接对应第 5 节原型中的 EventLog、A2ATask、ToolGrant、Approval 和 AuditEntry，而不是仅用于记号说明。

上述授权层描述对象语义；与之正交，系统部署还跨越事件接入域、智能体执行域和外部工具域，由此形成两个信任边界（trust boundary, TB）：TB1 位于外部来源与 Agent OS 之间，TB2 位于 Agent OS 与外部工具之间。跨越 TB1 的结构化字段不自动获得事件类型的声明权；跨越 TB2 的模型输出不自动获得工具执行权。

2.2 跨层授权状态迁移

令 $B_C(e)$ 表示事件来源与类型满足某个版本化 Connector 契约， $D_P(e, a) \in \{\text{allow}, \text{deny}, \text{approval}\}$ 表示目标智能体策略判定。审批状态 q 从 pending 只能单次转移到 approved、rejected 或 expired；能力状态从 active 只能转移到 revoked 或 expired。允许工具调用到达上游的状态迁移为

$$\Sigma_0 \xrightarrow{\text{ingest}(e)} \Sigma_1 \xrightarrow{\text{admit}(e, a)} \Sigma_2 \xrightarrow{\text{create}(t)} \Sigma_3 \xrightarrow{\text{issue}(g)} \Sigma_4 \xrightarrow{\text{invoke}(c)} \Sigma_5 \xrightarrow{\text{forward}(c)} \Sigma_6. \quad (3)$$

式 (3) 中，admit 完成 $H_E \rightarrow H_T$ 的授权传递，issue 建立 $H_T \rightarrow H_C$ 的授权依据，invoke 表示运行时提出调用，forward 表示调用通过授权检查后转发至上游。任一前置条件失败都会进入拒绝、待审批或终止状态，不能跳过相应转换。第 4 节算法实现这些转换，第 6 节分别通过准入消融、双 PEP 配对执行和并发状态实验检查其前置条件与单调性。

2.3 端到端安全性质

本文将任务作用域能力定义为由可信治理平面签发、授予特定任务在给定期限内调用指定工具集合的授权对象。它不是模型声明、工具名字符串或可脱离任务转用的凭据；其语义由签发依据、对象绑定和生命周期共同决定。令 $\text{Issued}(g, e, t, a, m, U, exp)$ 表示 g 由获准的 e, a 创建任务 t 后签发，并绑定服务 m 、允许工具集合 U 和期限 exp 。定义

$$\text{Admit}(e, a) \triangleq B_C(e) \wedge (D_P(e, a) = \text{allow} \vee \text{Approved}(e, a)), \quad (4)$$

$$\text{ValidGrant}(g, e, t, a, m, \tau) \triangleq \text{Issued}(g, e, t, a, m, U(g), exp(g)) \wedge \text{active}(g, \tau) \wedge \text{bind}(g, e, t, a, m). \quad (5)$$

其中 τ 为调用时刻, $\text{active}(g, \tau)$ 要求 $\text{state}(g) = \text{active}$ 且 $\tau < \text{exp}(g)$; $\text{Forwarded}(c)$ 表示调用 c 已通过调用时 PEP 并被转发至上游工具端点。原型通过持久化能力摘要和 PEP 校验实现上述语义; 本文不据此声称能力具有独立于可信治理主机的密码学不可伪造性。本文要求系统满足以下可检查性质。

11. 任务来源闭环: 若创建 t , 则存在 e, a 使 $\text{Admit}(e, a)$ 成立且 t 绑定 e, a ;
12. 能力作用域闭环: 若签发 g , 则它只绑定一个获准任务及其智能体、MCP 服务和允许工具集合, 且状态转移单调;
13. 调用授权安全: 若调用 c 已转发至上游, 则必存在 e, t, g, a, m 使

$$\text{Forwarded}(c) \Rightarrow \text{Admit}(e, a) \wedge \text{ValidGrant}(g, e, t, a, m, \tau) \wedge \text{tool}(c) \in U(g) \wedge e \prec t \prec g \prec c; \quad (6)$$

14. 证据连续性: 对同一 trace 的证据序列 $L_\rho = \langle l_1, \dots, l_n \rangle$, 序号连续、对象依赖满足状态迁移顺序, 且每项前驱哈希等于上一项内容哈希。

据此, 把治理目标定义为安全保持、可用性保持和可问责性三者的合取:

$$\text{GovOK}(\pi, \mathcal{W}) \triangleq \text{Sound}_{\text{I1-I3}}(\pi, \mathcal{W}) \wedge \text{Preserve}(\pi, \mathcal{W}_{\text{allow}}) \wedge \text{Accountable}_{\text{I4}}(\pi, \mathcal{W}), \quad (7)$$

其中策略配置 π 在工作负载 $\mathcal{W}$ 上必须满足 I1-I3; 对契约、策略和工具集合均允许且无外部故障的 $\mathcal{W}_{\text{allow}}$, 不得由治理机制引入拒绝; 每个治理终态还必须产生满足 I4 的证据。式 (6) 给出中心安全约束, 式 (7) 则避免以“全部拒绝”获得表面安全。第 6 节的 RQ1、RQ2 和 RQ3 分别检验这三个目标分量。

3 E2AG 总体架构

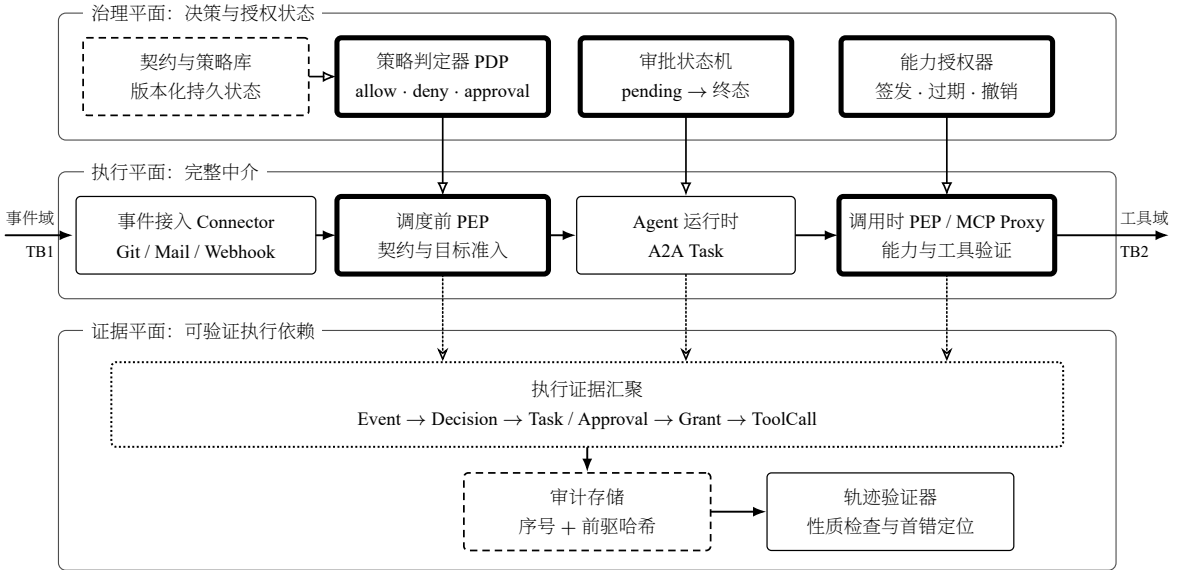


图 1 E2AG 总体架构。三个等宽平面按对象列对齐; 实心箭头、空心三角箭头和点线空心燕尾箭头分别表示执行数据、治理控制和证据写入, 双线框和虚线框分别表示 E2AG 强制组件和持久状态。

图 1 给出 E2AG 的静态系统架构。治理平面拥有授权决策及其持久状态, 执行平面消费治理结果并实施完整中介, 证据平面接收两个执行点和中间对象的状态变化。三个平面共享 trace 和对象标识, 但职责不同: PDP 计算策略, PEP 阻止未获准状态迁移, 证据平面记录一次决策依赖哪些对象。这里的“平面”回答组件由谁负责,“层次”回答授权约束哪个对象; 一个平面可以同时服务多个授权层。

3.1 治理平面与授权状态

治理平面的设计动机是把授权依据从模型上下文分离, 并为跨层迁移提供唯一的可信状态源。它拥有版本化来源-类型契约、目标智能体策略、审批终态和任务能力生命周期; 输入为标准化事件、目标与环境上下文, 输出为 **allow**、**deny** 或 **approval** 以及能力参数。契约与策略库存储 B_C 和 D_P 的判定依据, 治理判定器计算结果, 审批管理器以条件更新完成一次性终态, 任务能力管理器负责签发、过期和撤销。

治理状态不暴露给模型修改，模型只能消费与其任务绑定的能力，不能自行改变 $U(g)$ 、 $exp(g)$ 或 $state(g)$ 。该约束为 I1、I2 提供持久状态基础，并在第 4.1–4.3 节分别落实为来源契约、目标策略和能力签发规则；第 5 节的 EventLog、Approval 与 ToolGrant 是这些状态的实现载体。

3.2 执行平面与完整中介

执行平面的设计动机是让所有安全相关状态迁移经过可枚举且不可绕过的系统窄腰。调度前 PEP 位于所有 Connector 汇合到任务创建的位置，观察事件来源、类型、目标智能体和环境上下文；其输出是拒绝、待审批或绑定事件的任务。调用时 PEP 位于 MCP 上游凭据之前，观察任务能力、调用时刻和模型最终选择的工具；其输出是本地拒绝或转发后的工具结果。

调度前 PEP 不能预测任务创建后的实际工具选择，调用时 PEP 也不能仅凭工具名恢复来源声明权，因此两个执行点并非重复检查。二者分别强制 $H_E \rightarrow H_T$ 和 $H_T \rightarrow H_C$ 的授权传递，共同保持 I1–I3；第 4.4 节算法给出其前置条件，RQ2 的双执行点配对实验通过移除任一执行点构造可观测反例。

3.3 证据平面

证据平面的设计动机是使治理结果能够由对象依赖复核，而不是依赖分散文本日志进行事后猜测。它接收两个 PEP 以及审批、任务和能力管理器产生的阶段事件，拥有按 trace 排序的追加记录和前驱哈希，输出链完整性结果、首个失败阶段及其关联对象。拒绝或待审批事件同样写入终态证据，但不伪造不存在的任务或能力；获准路径则继续追加事件、任务、能力、调用和结果依赖。

验证器先检查记录内容和顺序，再依据式 (3) 检查前驱阶段，因此证据平面保持 I4，并为 I1–I3 提供可复核的执行见证。第 4.5 节定义证据结构与验证边界，RQ3 通过阶段故障和链内篡改检验定位能力；外部整体回滚不在当前保证范围内。

4 跨层能力治理机制

4.1 来源–类型能力契约

事件模式验证只回答字段是否合法。E2AG 在 Connector 描述中增加来源模式集合，并把它与 Connector 可声明的事件类型绑定。契约判定先检查基本 CloudEvent 结构，再查找同时满足来源与类型的版本化契约。未找到绑定时默认拒绝，因此结构合法的 `source=webhook/attacker,type=git.push` 不能借用 Git Connector 的事件语义；这对应引言贯穿示例中“伪造来源但选择集合内工具”的第一条反事实分支。契约输出包含匹配契约、策略版本和稳定原因码，成为目标策略的可信输入及证据链首项。

该机制拥有的是 H_E 的事件声明权，而不是目标任务或工具的最终执行权。对事件 e ，只有 $BC(e)$ 成立才进入目标解析；拒绝结果直接形成终态证据，不创建 t 或 g 。因此来源–类型契约保持 I1 的第一个前置条件，并在 RQ1 的 ContractGuard 配置中与目标策略独立开关，以检验二者是否覆盖不同违规对象。

4.2 目标策略与审批状态

对候选目标 a ，E2AG 比较事件来源、类型、声明动作、请求工具和运行环境。任一显式允许集合不匹配即返回 deny；风险条件命中返回 approval；其余返回 allow。approval 不等价于临时放行，只有审批状态以原子条件更新从 pending 单次转移到 approved 后才允许创建任务。rejected 和 expired 均为不可逆终态，重复请求不能恢复为 pending。

目标策略的输入包含已匹配契约、候选智能体及环境上下文，允许结果同时确定服务 m_a 、工具集合 U_a 和期限 exp_a ，供能力签发使用。该设计把 $H_E \rightarrow H_T$ 的转移和后续能力参数放在同一次可审计决策中，避免任务创建后再由模型扩大范围；审批竟态则由条件更新保持单终态不变量，并在 RQ3 的 approve/reject 并发实验中检查。

4.3 任务作用域能力

目标策略允许后，系统创建任务 t 并签发任务作用域能力

$$g = \langle \rho, id(e), id(t), id(a), id(m), U, exp, state, version \rangle. \quad (8)$$

式 (8) 中， ρ 为 trace 标识， $id(\cdot)$ 为对象标识， U 、 exp 、 $state$ 和 $version$ 分别表示允许工具集合、期限、生命周期状态和决策版本。签发要求 $Admit(e, a)$ 成立、 t 绑定 e, a ，且 m, U, exp 来自该目标策略的允许结果；因此 Issued 不是任意构造元组的事实，而是可信任务创建分支产生的状态。

调用时 PEP 使用 ρ 和对象标识检查跨层绑定，以 U 检查工具成员关系，并以 exp 与 $state$ 检查时效和生命周期。能力令牌只在任务运行时可见，持久层保存摘要；任务完成、失败或取消后转为 **revoked**，超过期限转为 **expired**。这些使用条件与式 (5) 共同闭合能力的签发、使用和终止语义。

4.4 双执行点授权算法

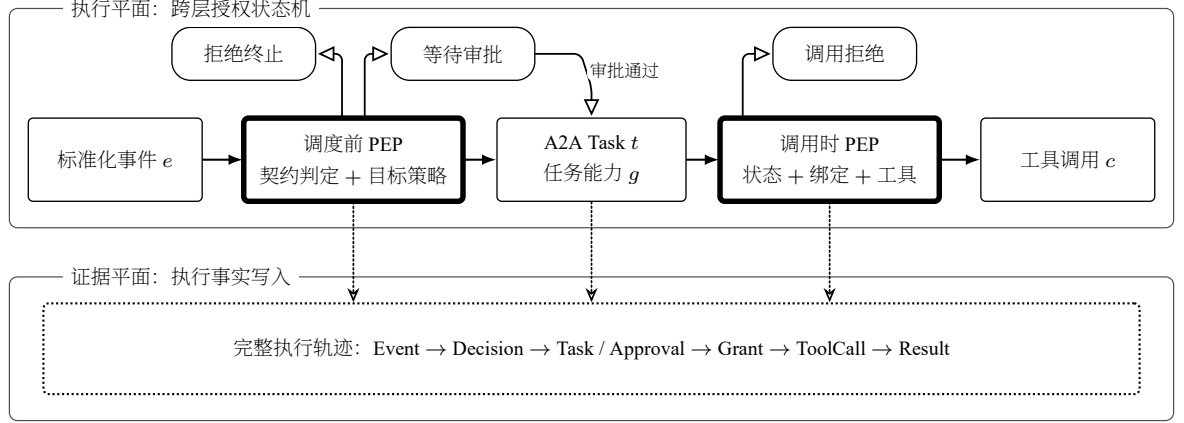


图2 E2AG 跨层授权执行流程。两个等宽平面共享左右边界；实心箭头表示主执行路径，空心三角箭头表示治理分支，点线空心燕尾箭头表示证据写入，圆角胶囊表示暂停或终止状态。

图2描述单个事件的动态流程，与图1的静态组件关系分离。算法1将式(3)实现为两个不可绕过的过程：事件接入过程先验证契约，再对每个目标执行策略和审批状态转换；只有准入成功才创建任务和能力。调用过程在接触上游凭据前检查状态、期限、对象绑定和工具集合。两个过程均追加显式阶段结果。

为把图示流程写成可执行过程，下面先统一算法输入、返回值和辅助过程。 $\mathcal{C}$ 是版本化Connector契约集合， $\mathcal{P} = \{P_a \mid a \in \mathcal{A}\}$ 是目标策略族， $targets(e) \subseteq \mathcal{A}$ 是订阅与路由得到的候选目标集合， τ 是当前时刻。 $EvaluatePolicy(e, P_a, \tau)$ 返回 $\langle d_a, m_a, U_a, exp_a \rangle$ ： d_a 为三态决策， m_a 为获准服务， U_a 为允许工具集合， exp_a 为能力期限。 $NewTrace$ 创建trace， $Append$ 原子追加证据， $ConsumeApproval$ 消耗一次性审批终态， $CreateTask$ 和 $IssueCapability$ 创建绑定对象； $Active$ 、 $BindingsMatch$ 与 $ForwardToUpstream$ 分别检查生命周期、检查对象绑定和执行上游调用。 T_{new} 与 r 是过程内的任务集合和上游结果。

算法1 E2AG 双执行点跨层授权算法

```

1: procedure GOVERNEvent( $e, \mathcal{C}, \mathcal{P}, \tau$ )
2:    $\rho \leftarrow NewTrace$ 
3:    $d_C \leftarrow EvaluateContract(e, \mathcal{C}); Append(\rho, d_C)$ 
4:   if  $d_C = deny$  then
5:     return  $\emptyset$ 
6:   end if
7:    $T_{new} \leftarrow \emptyset$ 
8:   for all  $a \in targets(e)$  do
9:      $\langle d_a, m_a, U_a, exp_a \rangle \leftarrow EvaluatePolicy(e, P_a, \tau)$ 
10:     $Append(\rho, d_a)$ 
11:    if  $d_a = approval$  then
12:       $d_a \leftarrow ConsumeApproval(e, a, \rho)$ 
13:    end if
14:    if  $d_a = allow$  then

```

```

15:       $t \leftarrow \text{CREATETASK}(e, a, \rho)$ 
16:       $g \leftarrow \text{ISSUECAPABILITY}(\rho, e, t, a, m_a, U_a, \text{exp}_a)$ 
17:       $\text{APPEND}(\rho, \langle t, g \rangle); T_{new} \leftarrow T_{new} \cup \{t\}$ 
18:    end if
19:  end for
20:  return  $T_{new}$ 
21: end procedure
22: procedure AUTHORIZECALL( $c, e, t, g, \tau$ )
23:   if  $\neg \text{ACTIVE}(g, \tau)$  then
24:     return deny
25:   end if
26:   if  $\neg \text{BINDINGSMATCH}(g, e, t, c) \vee \text{tool}(c) \notin U(g)$  then
27:      $\text{APPEND}(\text{trace}(t), \langle c, \text{deny} \rangle);$  return deny
28:   end if
29:    $r \leftarrow \text{FORWARDTOUPSTREAM}(c)$ 
30:    $\text{APPEND}(\text{trace}(t), \langle c, \text{allow}, r \rangle);$  return  $r$ 
31: end procedure

```

4.5 执行证据与验证

每项证据 l_i 包含 sequence、stage、outcome、对象标识、前驱哈希和内容哈希。令 H 为 256 位安全散列算法（Secure Hash Algorithm 256-bit, SHA-256）， canon 为 JavaScript 对象表示法（JavaScript Object Notation, JSON）的确定性规范化函数，则

$$h_i = H(\text{canon}(l_i \setminus \{h_i\})), \quad l_i.\text{previous_hash} = h_{i-1}. \quad (9)$$

验证器先检查式 (9)，再根据 stage/outcome 与对象标识检查式 (3) 所需的前驱阶段。前一检查回答记录内容和顺序是否被改变，后一检查回答某个任务、能力或调用是否缺少授权前因；两者共同实现 I4，而不能由普通 trace 标识传播替代。

哈希链能够检测已取得记录的修改、换序、插入和中间删除，但没有外部 head/count 锚点时不能检测整条链的尾截断。因而本方法提供的是可信存储假设下的执行依赖验证，不把局部哈希连续性表述为数据库不可回滚；RQ3 分别用阶段故障和链内篡改检查已声明保证，用讨论部分限定外部锚定缺失带来的剩余风险。

4.6 安全性与复杂度分析

命题 1（双执行点完整中介）。若 (A1) 所有事件驱动任务只能由 GovernEvent 创建，(A2) 所有到达上游的 MCP 调用只能由 AuthorizeCall 转发，(A3) 治理状态不能被不可信输入方直接修改，则算法 1 保持式 (6)。

证明概要。设调用 c 已转发至上游。由 A2，它必经过 AuthorizeCall 且未在状态、期限、绑定或工具成员检查处返回 deny，因此存在满足 ValidGrant 且 $\text{tool}(c) \in U(g)$ 的 g 。能力只由 GovernEvent 在任务创建分支签发；由 A1，该分支只能在 $B_C(e)$ 成立且目标策略允许或审批已原子批准时执行，故 $\text{Admit}(e, a)$ 与 $\text{Issued}(g, e, t, a, m, U(g), \text{exp}(g))$ 成立，并建立 $e \prec t \prec g$ 。AuthorizeCall 接收同一绑定对象并追加调用，得到 $e \prec t \prec g \prec c$ ，从而式 (6) 成立。若移除任一假设或 PEP，可分别构造来源绑定不满足或任务后集合外请求的反例；第 6 节以配对执行观测这些反例的上游可达性。□

在安全性之外，算法还需控制调用时检查成本。设契约数为 $|C|$ 、策略维度数为 k 、允许工具集合使用哈希集合。朴素契约匹配为 $O(|C|)$ ，目标策略判定为 $O(k)$ ，调用时状态、绑定和工具成员检查期望为 $O(1)$ ，每项证据追加为 $O(1)$ 。该分析说明调用时 PEP 不随历史 trace 长度线性扫描；实际端到端开销仍受数据库、模型和远程工具主导，本文不把本地微基准外推为生产性能。

5 原型系统实现

本文在一个开源事件驱动智能体操作系统原型上实现 E2AG。为保持匿名评审，仓库、分支和部署地址在当前稿件中以角色名表示，解除匿名后公开。原型已有 Connector、CloudEvents 标准化、订阅匹配、事件调度、A2A Task 和 MCP 配置管理。E2AG 增加契约与策略判定器、调度前 PEP、审批管理器、任务能力管理器、MCP 调用 PEP 和执行证据验证器。

调度前 PEP 位于所有 Connector 汇合到 A2ATask 创建的统一 dispatcher。EventLog 保存事件及契约判定，A2ATask 通过 context 和 trace 与事件关联，ToolGrant 保存式 (8) 的能力摘要和生命周期状态。MCP PEP 代理基于超文本传输协议 (Hypertext Transfer Protocol, HTTP) 的远程 Streamable HTTP 传输：它先验证任务能力，再转发获准调用；tools/list 结果按任务允许集合裁剪，避免向任务暴露无权调用的工具。

实现将纯判定与输入/输出 (input/output, I/O) 分离。纯函数负责契约和目标策略，dispatcher 负责对象创建与证据持久化，MCP PEP 负责调用转发前授权。实验因此可以在同一执行路径上独立开关契约、目标策略和两个 PEP，保持数据、模型输出和上游工具一致。

上述划分解决了判定位置和实验隔离问题，但并发状态仍可能破坏状态迁移的单调性。事件去重最初采用“先查询、后插入”，并发 replay 会绕过检查；修复后增加带期限的唯一 EventDedupClaim，使数据库写入成为去重线性化点。审批使用 pending、approved、rejected、expired 四态和条件更新，使 approve/reject 竞争至多一个成功终态。这两项实现对应状态迁移模型的单调性要求。

6 实验设计与结果分析

6.1 研究问题

实验围绕以下研究问题 (research question, RQ) 而不是围绕脚本数量组织：

- **RQ1**：来源契约和目标策略是否分别提供独立安全收益，组合后能否保持正常事件可用性？对应 I1；
- **RQ2**：两个执行点是否具有不可替代的上下文，完整方法能否阻止未授权工具调用到达真实 HTTP 上游？对应 I2-I3；
- **RQ3**：执行证据能否定位首个治理失败阶段，去重与审批状态在并发下是否保持单调性？对应 I4 和式 (3)。

6.2 工作负载、规模与实验边界

表 2 区分独立规模和重复次数。正式有效性结论来自 60 例治理规则冻结矩阵；四名未参与语料构造的复核者通过盲表检查其规则标签，复核不增加工作负载规模。700 次固定种子变异仅作为机制压力覆盖，其中序列化去重后有 319 个不同用例。确定性端到端重复用于证明状态稳定和配对因果，不增加工作负载多样性。本研究早期已冻结一个模型在三个固定场景中的 30 个工具选择结果，本版只复用这些不可变结果进行配对回放，不新增模型调用，也不由模型构造治理回归向量。另在自有设施上以公开测试仓库的真实推送构造允许路径正对照和固定集合外请求负对照，检查 ToolGrant 与运行时 PEP 的一致性；该配对轨迹不计入统计样本。

表 2 当前实验的独立维度与操作规模

维度	当前覆盖	证据边界
事件与规则情形	7 类来源；30 直接放行 +26 拒绝 +4 审批；7 类变异算子	四人盲表复核；变异集为合成压力数据
标签复核	4 名复核者 ×60 例	检查规则可复核性，不证明分布代表性
治理配置	Contract×Policy 4 种；双 PEP 4 种	内部消融，不等价于外部方法复现
外部策略引擎	OPA v1.17.0；49 例可调用切片 +8 例接口补充	隔离工具边界可见性，不报告本地时延排名
端到端路径	480 条确定性路径；90 条模型决策配对路径	重复验证稳定性，不代表独立样本规模
模型与提示	1 个模型；每场景 1 个固定提示	不估计开放环境中的模型违规选择概率
外部端点	loopback MCP canary；1 组公开仓库-自有设施配对回归	验证部署闭合与 grant-PEP 一致性，不构成统计工作负载
状态与并发	SQLite；8/32 并发；每配置 100 轮	不外推其他数据库后端

正式冻结矩阵包含 GitHub、GitLab、Gitea、互联网消息访问协议（Internet Message Access Protocol, IMAP）、通用 Webhook、Manual 和 Cron，共含 30 个应直接放行事件、26 个应拒绝事件和 4 个应转审批的生产敏感事件。冻结作者标签为便于早期消融，将后两类合并编码为 **attack**；盲评允许复核者独立判断事件类别。为避免把高风险但合规的审批事件等同于恶意攻击，本文以预期治理结果（放行、拒绝或审批）作为主要标签，并把事件类别一致性单独报告。所有样本满足基本 CloudEvent 结构，以避免把解析失败计为跨层治理收益。四名复核者仅接收移除作者标签的事件字段与目标治理声明，分别标注事件类别、首个治理层和完整 E2AG 预期决策。报告非直接放行事件处置率、正常通过率、Wilson 95% 置信区间以及多复核者 Fleiss κ 。

6.3 基准方法与公平性

表 3 给出基准。内部配置共享代码路径、事件、模型决策和上游工具，仅切换治理位置。ContractGuard、DispatchGuard 和 RuntimeGuard 分别对应事件声明绑定、前置策略门控和调用时工具约束三类单点思路，用于隔离 E2AG 组件；它们不是 AgentSpec 或 CaMcL 原实现的弱化复现。为增加独立实现参照，本文另以官方 OPA v1.17.0 执行通用 default-deny Rego 工具允许集策略（OPA-Tool）[19]。该基线只接收 MCP 方法、工具名和任务允许集合，不接收事件来源、目标动作、审批及能力生命周期；比较用于隔离工具边界的可见上下文，不用于评价 OPA 通用引擎的能力上限，也不报告本地时延。其他外部方法仍只在表 1 按保护对象比较。

表 3 实验基准方法与治理能力

编号	名称	开启机制	隔离对象
C0P0 / G0R0	NoGuard	无跨层治理	无治理参照
C1P0	ContractGuard	来源-类型契约	事件声明权限
C0P1 / G1R0	DispatchGuard	目标策略/调度前 PEP	任务创建权限
G0R1	RuntimeGuard	任务工具允许集合	工具调用权限
OPA-T	OPA-Tool	OPA/Rego 工具允许集合	工具调用对象
C1P1 / G1R1	E2AG	准入与运行时能力	完整方法

6.4 RQ1：跨层任务准入

表 4 来源契约与目标策略的完整消融

配置	正确处置非直接放行	处置率	正常通过	正常通过率
C0P0	0/30	0.00%	30/30	100.00%
C1P0	10/30	33.33%	30/30	100.00%
C0P1	20/30	66.67%	30/30	100.00%
C1P1	30/30	100.00%	30/30	100.00%

表 4 显示 ContractGuard 只阻断来源-类型绑定违规，非直接放行事件处置率置信区间为 [19.23%, 51.22%]；当来源具有合法契约但目标智能体不允许其动作或工具时，契约不产生作用。DispatchGuard 阻断 16 个目标能力不匹配事件，并将 4 个生产敏感事件转入审批，区间为 [48.78%, 80.77%]，但无法识别来源绑定不匹配。完整组合覆盖两类互不重叠的治理原因，区间为 [88.65%, 100%]。四组正常通过率相同，说明差异来自治理对象而不是普遍收紧接入。

为确认上述预期决策并非仅由作者解释，四名未参与语料构造的复核者独立检查同一冻结矩阵。复核者对首个治理层和完整 E2AG 预期决策均达到 60/60 逐例全体一致，Fleiss κ 均为 1.00。事件类别有 56/60 例全体一致，原始一致度为 0.966667，Fleiss $\kappa = 0.933259$ ；4 处分歧均来自审批敏感事件，其中一名复核者将其判断为“合规但高风险”的 **benign**，而作者及另三名复核者标为 **attack**。该复核者仍对这 4 例的治理层 **approval** 和决策 **approval_required** 与其他复核者完全一致。四份表的冻结输入字段均未被修改，无缺失或非法值，且逐例备注在任意两名复核者间没有完全相同项。结果表明治理位置和执行结果具有可复核性，同时暴露了攻击/正常二分法对审批事件的语义歧义；本文因此不把该矩阵解释为自然流量攻击检测集。

在冻结矩阵之外，固定种子压力集进一步检查上述机制分工是否随输入变异而改变。压力集对 7 种变异算子各执行 100 次，NoGuard、ContractGuard 和完整 E2AG 的精确决策率分别为 0、57.14% 和 100%。ContractGuard 只覆盖必填字段、规范版本、来源-类型交叉和未知类型 4 类变异，完整方法继续覆盖需审批动作与目标能力不匹配。该结果验证实现对不同变异算子的稳定分工，但由于样本由规则生成，不用于估计真实分布中的检出率。

6.5 RQ2：双执行点与上游调用可达性

6.5.1 独立策略引擎的工具边界基线

从 60 例冻结矩阵中选择已经形成可比较工具授权对象的用例：目标非空、事件显式声明 `requested_tool`，且目标策略包含 `allowed_tools`。该规则得到 49 例可调用切片，包括 30 例正常和 19 例跨层违规；其余 11 例在工具对象形成前终止或未声明工具。若把“没有工具对象”直接计作 OPA 拒绝，会虚增工具边界覆盖，故明确排除。OPA-Tool 只接收 `tools/call`、工具名和逐例任务允许集合；Rego 策略规定工具名匹配允许模式时通过，不调用 E2AG 判定代码。NoGuard 与 E2AG 行从同一冻结运行的 C0P0、C1P1 结果按这 49 个编号投影得到。为保持三态决策语义，正常例只有 `allow` 计为通过；违规例的 `deny` 或 `approval` 均计为“非允许”，表示该请求不会直接进入工具调用。

表 5 49 例可调用切片上的独立策略引擎基线

方法	正常通过	违规非允许	总体对齐
NoGuard	30/30	0/19	30/49
OPA-Tool v1.17.0	30/30	4/19	34/49
E2AG	30/30	19/19	49/49

表 5 显示 OPA-Tool 保持 30/30 正常调用，并对 19 例违规中的 4 例返回非允许。分层结果为：工具策略层 4/15 非允许，审批层 0/4 非允许；前 4 例均可由工具集合不匹配在调用边界直接观察。其余 15 例的工具名本身在允许集合中，违规信息位于来源、事件类型、目标动作或审批状态，工具边界输入不足以区分。完整 E2AG 通过调度前 PEP 补充这些上下文，因而在相同切片上得到 19/19 非允许。该比较不表示 OPA 引擎弱于 E2AG：若向 OPA 提供完整跨层对象和相应策略，它可以作为 E2AG 的 PDP；本文所解决的是对象构造、上下文传播、能力生命周期和 PEP 布置。补充接口集中的 8 个 `tools/call` 请求上，OPA-Tool 与 RuntimeGuard 均正确处理 4 个集合内和 4 个集合外工具，证明工具允许集语义可由独立引擎复现；另 2 个非 `tools/call` 方法不计入该补充集。实验固定 OPA 发布件、策略、输入和投影结果哈希，不报告单机进程启动时延。

6.5.2 双执行点的确定性与模型决策配对执行

工具边界基线说明了输入可见性差异；进一步的问题是，该差异是否会转化为真实上游调用。为此，确定性实验包含正常授权、来源不匹配、任务后集合外请求和需审批动作，在 4 种配置下各重复 30 次，共 480 条 dispatcher-SQLite-A2ATask-ToolGrant-MCP PEP 路径。表 6 报告真实上游可达性。

表 6 确定性端到端执行中的上游调用可达性

配置	正常到达	来源不匹配	集合外请求	需审批动作
G0R0	30/30	30/30	30/30	30/30
G1R0	30/30	0/30	30/30	0/30（审批）
G0R1	30/30	30/30	0/30	0/30
G1R1	30/30	0/30	0/30	0/30（审批）

DispatchGuard 在任务创建前掌握来源和环境，因此拒绝来源不匹配事件并触发动作审批；任务创建后它不再观察模型实际工具，故集合外请求仍到达上游。RuntimeGuard 检查任务能力中的工具集合，阻断全部集合外请求，却不能判定一个获准工具是否由来源不匹配事件触发。完整 E2AG 保留正常调用并阻止三类未授权调用到达上游。该配对反例与命题 1 的两个完整中介假设一一对应。

确定性路径固定治理输入和预期上游到达结果，仍未覆盖既有模型工具选择进入同一执行路径后的系统行为。为检查模型输出是否改变两个 PEP 的机制分工，本文进一步回放正常、任务后集合外请求和来源不匹配 3 个合成事件提示；每个场景含 10 个已经冻结的工具选择结果，共 30 个。每个不可变结果在 G1R0、G0R1 和 G1R1 中复用，形成 90 条配对执行路径；本版不重新调用模型，上游为真实 loopback HTTP MCP canary。

表 7 既有模型决策的配对执行路径

配置	正常上游到达	集合外请求到达	来源不匹配到达
G1R0	10/10	10/10	0/10
G0R1	10/10	0/10	10/10
G1R1	10/10	0/10	0/10

模型在集合外请求场景中均返回不在 grant 内的工具选择。为避免工具名称承载额外语义，本文仅按 grant 集合成员关系判定；结果文件保留原始标识供复核。表 7 与确定性结果一致：G1R0 不能阻止任务后的集合外请求，G0R1 不能识别工具合法但来源不匹配的事件，G1R1 同时阻止两类未授权调用到达上游。该实验验证模型调用进入真实 MCP PEP 后的系统行为，不把工具选择比例解释为开放环境中的模型违规选择概率。

6.5.3 自有设施上的治理一致性与集合外请求回归

为排除全部证据仅来自进程内生成器的疑问，本文在一台自有设施上另行部署仅绑定回环端口、使用独立数据库和工作区的 E2AG 实例，并在自有工具端点上执行配对回归。正对照沿用公开测试仓库的真实 GitHub push，验证 Connector、任务容器、ToolGrant、MCP PEP 与外部工具可以闭合。负对照使用该仓库的另一条真实事件，但集合外请求的工具名与参数由固定脚本直接构造，不由模型生成或选择；该负对照对应引言贯穿示例中“获准任务选择集合外工具”的第二条反事实分支，后续复验也只由确定性测试 harness 触发。

表 8 公开仓库-自有设施治理一致性配对回归

阶段	观测结果
允许路径正对照	匿名化提交摘要；任务 completed；5 次获准调用抵达自有工具端点；grant 终态 revoked
固定集合外请求负对照	grant 仅含 4 个评审工具；集合外请求返回 403 与 MCP_TOOL_NOT_GRANTED
未触达上游	拒绝审计的 upstream_status=null；canary 仍为 effective=0，记录数不变
因果与完整性	负对照 11 项审计链校验有效，包含 grant、tool_call/deny、revoke 与任务完成

该配对结果保留了真实公开仓库-自有设施-任务运行时-PEP-工具端点路径，同时把负向判断收缩为可复核的治理一致性性质：集合内调用能够到达上游，集合外调用由 PEP 本地拒绝且不改变上游状态。负对照完全由固定 harness 定义，模型不参与其构造或调度；该结果也不被解释为模型安全率、自然流量违规概率、吞吐量或外部方法比较。

6.6 RQ3：证据定位与并发状态

6.6.1 故障定位与链验证

对契约拒绝、策略拒绝、审批过期、任务能力过期和 MCP 工具拒绝各注入 20 次。表 9 显示 100 条 trace 均保持统一标识、包含到达终态所需阶段，并把首个治理失败定位到注入位置。原因在于验证器使用显式 stage/outcome 和对象依赖，而不是事后从文本日志猜测根因。

对内容修改、换序、trace 替换、前驱哈希替换、插入和中间删除的链内篡改，验证器均拒绝；没有外部锚点时尾截断仍不可检测，符合式 (9) 的能力边界。该结果支持的是已取得证据的阶段定位与链内完整性，不把日志存在本身等同于外部不可否认性。

表 9 故障注入的治理阶段定位与证据验证

故障阶段	轨迹数	正确定位	链有效	阶段完整
契约拒绝	20	20	20	20
目标策略拒绝	20	20	20	20
审批过期	20	20	20	20
任务能力过期	20	20	20	20
MCP 工具拒绝	20	20	20	20

6.6.2 并发状态不变量

并发实验首先发现原有先查后插去重在 8 并发的 100 轮中均产生重复 EventLog，共创建 588 条记录。加入唯一去重声明后，表 10 的四组实验均满足单日志或单终态不变量。该结果证明安全性质还依赖数据库状态转移，而不只是纯判定函数。

表 10 修复后的 SQLite 并发状态不变量

场景	并发	请求数	成功创建/终态	不变量违规
event replay	8	800	100	0
event replay	32	3200	100	0
approve/reject	8	800	100	0
approve/reject	32	3200	100	0

7 讨论

7.1 方法适用范围

E2AG 适用于外部事件经统一调度入口创建任务、外部工具调用经可中介出口执行的 Agent OS。其治理目标是使调用不超出获准来源、目标和工具集合，而不是判定自然语言意图类别。若请求使用已授权工具和合法工具名，只在参数中携带不符合约束的数据，当前工具粒度能力无法区分；数据流能力或参数谓词可作为正交扩展，而不改变本文事件-任务-工具的授权层定义。

命题 1 还依赖所有任务创建与工具调用分别经过两个 PEP。当前原型验证远程 Streamable HTTP 的任务模式 MCP 路径；标准输入/输出（standard input/output, stdio）、服务器发送事件（Server-Sent Events, SSE）、Skill、内嵌服务和绕过 MCP 的本地调用尚未纳入主张。移植到其他 Agent OS 时，必须重新识别任务创建入口和工具调用出口的系统窄腰，并验证假设 A1-A3 后才能沿用安全结论。

7.2 有效性威胁

7.2.1 构念效度

冻结矩阵按治理层构造，适合验证机制分工，却不能直接表示自然流量中的“攻击率”。四名未参与构造的复核者对治理层和预期决策完全一致，但在 4 个审批敏感事件的攻击/正常二分标签上出现语义分歧。为降低标签构念对结论的影响，本文以放行、拒绝或审批的预期治理结果为主要标签，并单独报告类别一致性；剩余风险是矩阵仍由预设治理规则定义，因此本文只主张规则可复核性和机制覆盖，不主张自然分布检测能力。

7.2.2 内部有效性

既有模型结果采用冻结提示与工具选择，使相同决策可以在不同治理配置下配对复用，从而隔离 PEP 布置对上游调用可达性的影响。该控制减少模型随机性造成的混杂，但无法估计开放环境中的模型违规选择概率。OPA 可调用切片按是否存在工具授权对象的预先结构规则选取，并报告全部排除编号，以避免结果导向筛选；不过 Rego 策略仍由本文按公开接口适配且仅观察工具边界，因此该基线用于验证上下文可见性差异，不替代 AgentSpec、OAP、ToolGuardian 或 Agent libOS 的原系统复现。

7.2.3 外部有效性

当前实现限于一个 Agent OS 原型、一个模型、一个合成 HTTP MCP canary、一组公开仓库-自有设施配对回归和 SQLite。现场回归证明真实 GitHub payload、任务运行时与外部 MCP 服务能够闭合，并为 grant-PEP 一致性提供部署证据；七类来源和压力变异也扩大了输入机制覆盖。然而，单仓库、单组配对和共享上游状态不能代表自然工作负载，SQLite 结果亦不能外推到其他数据库或第二种 Agent OS。后续验证应优先增加仓库、Connector、工具传输和系统实现等独立维度，而不是增加相同确定性用例的重复次数。

7.3 审计证据的保证范围

哈希链保证已取得记录的内容和顺序，并由阶段验证器检查对象依赖；它不能单独证明数据库未被整体回滚或从尾部截断。当前实现以可信治理存储为前提，因此 RQ3 支持 I4 的链内完整性和失败定位，不构成跨组织不可否认性。外部透明日志或周期性 Merkle 根锚定可以强化证据新鲜性与完整性，但不改变 I1-I3 的执行授权语义。

8 总结

本文针对事件驱动 Agent OS 中事件来源、任务创建和工具调用跨越不同信任域的问题，提出跨层能力治理方法 E2AG。该方法用来源-类型契约建立事件声明权，用目标策略和审批控制任务创建，用任务作用域能力与调用时 PEP 约束模型最终选择的工具，并通过统一执行证据连接各阶段对象。状态迁移模型和完整中介命题说明两个执行点为何缺一不可；独立 OPA 引擎基线进一步表明，工具集合判定可以由通用 PDP 执行，但只有跨层对象绑定和双执行点才能覆盖工具边界不可见的来源、任务与审批约束。消融、端到端配对执行、既有模型决策回放、故障注入与并发实验分别验证任务来源闭环、调用授权安全、证据连续性和状态单调性。E2AG 的核心价值不是判定模型语言层输入类别，而是把非确定性模型决策置于可执行、可审计且对象绑定的系统授权边界内。

References

- [1] Mei K, Zhu X, Xu W, et al. AIOS: LLM agent operating system. In: Proc. of the 2nd Conf. on Language Modeling. Montreal: OpenReview, 2025.
- [2] Wang L, Ma C, Feng X, et al. A survey on large language model based autonomous agents. Frontiers of Computer Science, 2024, 18(6): 186345. [doi: 10.1007/s11704-024-40231-1]
- [3] Huang HY, Li SL, Lan TW, et al. A survey on the safety of large language model: Classification, evaluation, attribution, mitigation and prospect. CAAI Transactions on Intelligent Systems, 2025, 20(1): 2–32 (in Chinese with English abstract). [doi: 10.11992/tis.202401006]
- [4] Mu YY, Chen HX, Li HW. Advances in security and privacy-preserving techniques for large language models. Journal of Cybersecurity, 2024, 2(1): 40–49 (in Chinese with English abstract). [doi: 10.20172/j.issn.2097-3136.240103]
- [5] Zhang X, Li CZ, Xu N, Zhang LT. Security challenges and response mechanisms for trustworthy large language model agents. Information and Communications Technology and Policy, 2025, 51(1): 33–37 (in Chinese with English abstract). [doi: 10.12267/j.issn.2096-5931.2025.01.005]
- [6] Abdelnabi S, Greshake K, Mishra S, et al. Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. In: Proc. of the 16th ACM Workshop on Artificial Intelligence and Security. New York: ACM, 2023. 79–90. [doi: 10.1145/3605764.3623985]
- [7] Zhan Q, Liang Z, Ying Z, Kang D. InjecAgent: Benchmarking indirect prompt injections in tool-integrated large language model agents. In: Proc. of the Findings of ACL 2024. Bangkok: Association for Computational Linguistics, 2024. 10471–10506. [doi: 10.18653/v1/2024.findings-acl.624]
- [8] Debenedetti E, Zhang J, Balunović M, et al. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. Advances in Neural Information Processing Systems, 2024, 37: 82895–82920. [doi: 10.52202/079017-2636]
- [9] Ruan Y, Dong H, Wang A, et al. Identifying the risks of LM agents with an LM-emulated sandbox. In: Proc. of the 12th Int'l Conf. on Learning Representations. Vienna: OpenReview, 2024.
- [10] Wang H, Poskitt CM, Sun J. AgentSpec: Customizable runtime enforcement for safe and reliable LLM agents. In: Proc. of the 48th IEEE/ACM Int'l Conf. on Software Engineering. New York: ACM, 2026. 12 pages. [doi: 10.1145/3744916.3764546]
- [11] Debenedetti E, Shumailov I, Fan T, et al. Defeating prompt injections by design. In: Proc. of the IEEE Conf. on Secure and Trustworthy Machine Learning, 2026.
- [12] Uchibeke U. Before the Tool Call: Deterministic Pre-Action Authorization for Autonomous AI Agents. arXiv:2603.20953, 2026.

- [13] Ravindran A, Deochake S. ToolGuardian: Declarative Security for AI Agent-Tool Interactions. arXiv:2607.21835, 2026.
- [14] El Helou M, Ryder B, Troiani C, et al. Hybrid Inspection and Task-Based Access Control in Zero-Trust Agentic AI. arXiv:2605.02682, 2026.
- [15] Zhang YQ. Agent libOS: A Runtime Substrate for Capability-Controlled Self-Evolving LLM Agents. arXiv:2606.03895v2, 2026.
- [16] Cloud Native Computing Foundation. CloudEvents Specification, Version 1.0.2, 2022. <https://github.com/cloudevents/spec/tree/ce@v1.0.2>. [2026-08-14]
- [17] A2A Protocol Project. Agent2Agent Protocol, Version 1.0.0, 2026. <https://a2a-protocol.org/v1.0.0/>. [2026-08-17]
- [18] Model Context Protocol Contributors. Model Context Protocol Specification, Revision 2025-06-18. <https://modelcontextprotocol.io/specification/2025-06-18/>. [2026-08-14]
- [19] Open Policy Agent. OPA documentation; Release v1.17.0. <https://www.openpolicyagent.org/docs>; <https://github.com/open-policy-agent/opa/releases/tag/v1.17.0>. [2026-08-17]
- [20] Anderson JP. Computer Security Technology Planning Study. Technical Report ESD-TR-73-51, 1972.
- [21] Saltzer JH, Schroeder MD. The protection of information in computer systems. *Proc. of the IEEE*, 1975, 63(9): 1278–1308. [doi: 10.1109/PROC.1975.9939]
- [22] Dennis JB, Van Horn EC. Programming semantics for multiprogrammed computations. *Communications of the ACM*, 1966, 9(3): 143–155. [doi: 10.1145/365230.365252]
- [23] Birgisson A, Politz JG, Erlingsson Ú, et al. Macaroons: Cookies with contextual caveats for decentralized authorization in the cloud. In: *Proc. of the Network and Distributed System Security Symp.* San Diego: Internet Society, 2014.
- [24] Xu JL, Wang SL, Li LM, et al. Formal verification of capability-based access control in operating system kernel. *Journal of Software*, 2025, 36(8): 3570–3586 (in Chinese with English abstract). [doi: 10.13328/j.cnki.jos.007351]
- [25] W3C. Trace Context. W3C Recommendation, 2021. <https://www.w3.org/TR/trace-context/>.
- [26] Haber S, Stornetta WS. How to time-stamp a digital document. *Journal of Cryptology*, 1991, 3(2): 99–111. [doi: 10.1007/BF00196791]
- [27] Torres-Arias S, Afzali H, Kuppusamy TK, et al. in-toto: Providing farm-to-table guarantees for bits and bytes. In: *Proc. of the 28th USENIX Security Symp.* Santa Clara: USENIX Association, 2019. 1393–1410.